POSITION PAPER

# Chambers for Automotive

## Sealed Ephemeral Sessions for Connected Vehicle Data Sovereignty

Arko Ganguli

April 2026 — Revised Draft

*This paper applies the Chambers sealed ephemeral computation model to connected vehicle architectures,*

*addressing the convergence of EU regulatory frameworks between September 2026 and December 2027.*

*Scope: private passenger vehicles. Fleet and commercial use cases are noted but not fully addressed.*

# 1. Executive Summary

A modern connected vehicle is a mobile sensor platform containing approximately 150 electronic control units, running 100 million lines of code, equipped with cameras, LiDAR, radar, GPS, and microphones, and maintaining a persistent cellular connection to the manufacturer's cloud backend. Every layer of this architecture generates data. None of it has a declared preservation boundary.

This paper proposes applying the Chambers sealed ephemeral computation model — an open-source project implemented as a working Rust substrate with 44 passing tests (github.com/therealgulkorinaga/chamber) — to connected vehicle architectures. Chambers introduces three concepts absent from current automotive software stacks: sealed drive sessions with ephemeral encryption keys, a typed preservation manifest declaring what data survives and for whom, and cryptographic burn semantics that destroy undeclared data when a drive session ends.

The primary intervention point is the telematics gateway — the highest-volume data egress channel. This paper also extends the Chambers boundary to four additional channels — Bluetooth, Wi-Fi, OBD-II, and V2X — each with its own enforcement point, threat model, and session lifecycle. All five enforcement points share one manifest schema and one burn engine.

This paper is scoped to private passenger vehicles. Fleet, commercial, and regulatory telematics use cases (e.g., tachographs, usage-based insurance black boxes) involve different data subjects, legal bases, and retention mandates. These are noted where relevant but are not fully addressed.

> *Legal disclaimer: The regulatory analysis in this paper identifies how the Chambers architecture supports compliance. It does not constitute a determination of compliance for any specific implementation. Legal determination requires case-by-case assessment by qualified counsel in the relevant jurisdiction.*

# 2. What Is Chambers

Chambers is a sealed ephemeral computation model. The reference implementation is an open-source Rust substrate (github.com/therealgulkorinaga/chamber) comprising an encrypted memory pool, a six-layer burn engine, native application isolation, and 44 passing tests.

The model was originally developed for general-purpose privacy-preserving computation. Its core proposition is that the unit of destruction matters as much as the fact of destruction. Rather than improving persistent environments (as Tails, Qubes OS, and container-based systems do), Chambers rejects persistence as the default, treating a typed, grammar-constrained "world" as the primary unit of computation — and destruction.

The model introduces five core concepts:

- **World:** a sealed, temporary computational environment with bounded inputs and outputs.
- **Grammar:** a typed schema declaring what operations are permitted within a world and what outputs may survive its destruction.

- **Preservation law:** an explicit declaration of what data persists beyond the world's lifetime, for whom, and under what conditions.
- **Burn engine:** a multi-layer destruction mechanism (logical, cryptographic, storage, memory, semantic) that enforces the preservation law by destroying everything not explicitly declared.
- **Sealed event:** a bounded, time-limited data capture triggered by a specific condition, declared in the grammar, and retained as a declared exception to ephemeral default.

This paper applies these concepts to the connected vehicle domain. It does not claim novelty in the underlying cryptographic primitives (ephemeral key management, session-based encryption, and cryptographic erasure are established techniques used in the Signal Protocol, AWS Nitro Enclaves, and Apple's per-session encryption). The contribution is the application of sealed ephemeral semantics to automotive telematics as an architectural compliance mechanism across multiple regulatory frameworks simultaneously.

## 2.1 Related Work

The Chambers model intersects with several existing automotive and security standards:

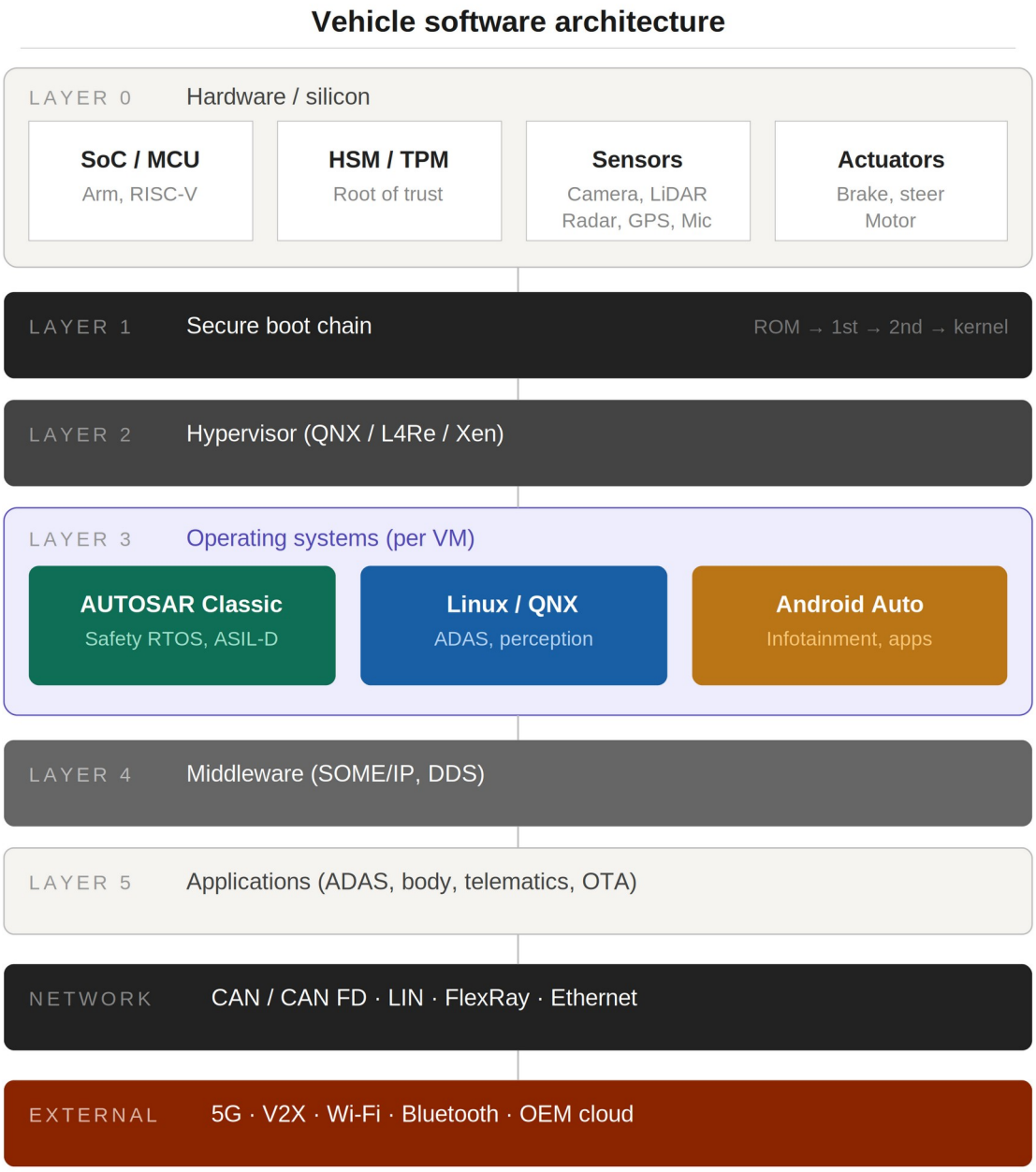
- **AUTOSAR Crypto Stack:** provides cryptographic service interfaces for ECU software, including key management and secure communication. Chambers operates at a higher architectural level, using the Crypto Stack's primitives to implement session-level ephemeral boundaries.
- **ISO/SAE 21434:** defines cybersecurity engineering requirements for road vehicles. Chambers provides an implementation pattern for several 21434 requirements, including threat analysis (clause 8), risk treatment (clause 9), and vulnerability management (clause 12), but does not replace the standard's process requirements.
- **TCG TPM 2.0 for Automotive:** the Trusted Computing Group's TPM specification provides the hardware root of trust on which Chambers' HSM-based key management depends. The burn engine's key destruction relies on TPM or HSM secure key deletion functions.
- **Signal Protocol (sealed sender):** implements ephemeral key exchange for messaging. Chambers applies analogous principles to vehicle data flows, with the preservation manifest serving a role comparable to Signal's session management, but for data retention rather than communication confidentiality.
- **AWS Nitro Enclaves:** provides isolated compute environments with attestation. Chambers' sealed sessions share the enclave model's isolation properties but apply them temporally (per drive session) rather than spatially (per compute instance).

# 3. The Problem: Persistence as Default Ontology

The connected vehicle's software architecture treats data persistence as the default behaviour at every layer. The bootloader logs. The kernel logs. The hypervisor maintains state. The middleware publishes state changes. The applications generate telemetry. The cloud backend stores everything indefinitely.

## 3.1 The Architecture

The modern software-defined vehicle operates on a layered architecture:




*QNX deployed in 275+ million vehicles (Dec 2025).*
*A typical vehicle runs ~100M lines of code across ~150 ECUs.*

The hypervisor layer — deployed in over 275 million vehicles via QNX alone — provides computational isolation between virtual machines. However, this isolation is for safety, not privacy. The hypervisor stops code from crossing boundaries but lets data flow freely.

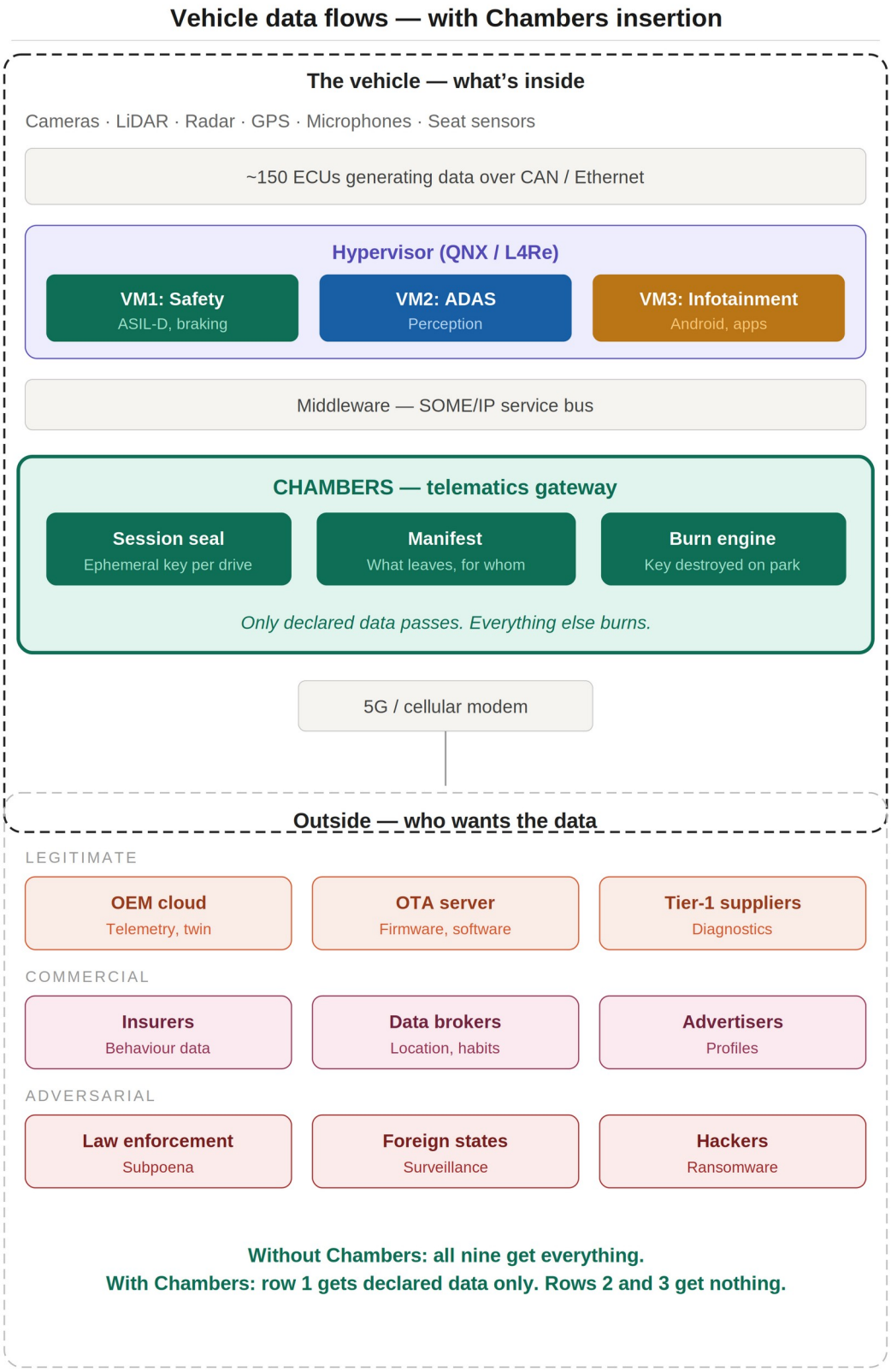
## 3.2 The Data Residue Problem

CAN bus metadata — even without payload content — reveals driving style, acceleration profiles, braking patterns, and route characteristics through message frequency and timing patterns alone.

From the driver’s perspective, the data that genuinely needs to survive a drive session is minimal: trip distance for maintenance scheduling, fault codes if something broke, and safety-critical event records required by regulation. Everything else exists because logging is the default behaviour of every software layer.

Some OEMs do publish data retention policies (e.g., Volvo’s integrated systems). However, a declared retention policy is not an architectural enforcement mechanism. The distinction between a policy promise and a system property is central to this paper.

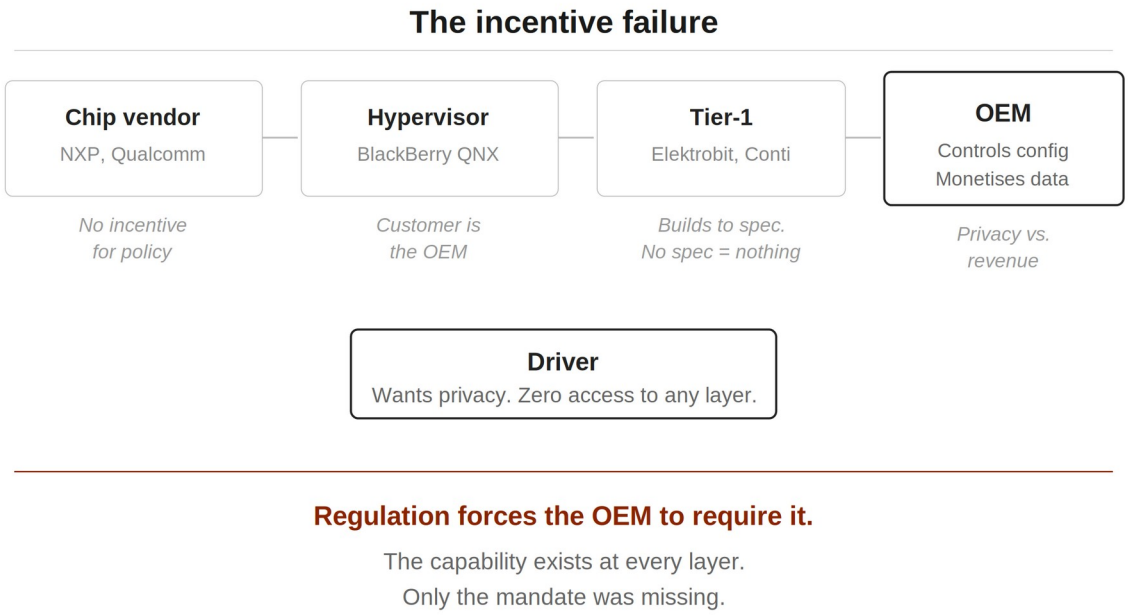
## 3.3 Who Benefits from the Data



The first three categories — OEM, tier-1 suppliers, and OTA servers — have legitimate engineering needs. The remaining six exploit the absence of an architectural boundary between functional and commercially motivated data retention.

# 4. The Incentive Failure

The capability to build ephemeral data boundaries exists at every layer. No participant in the value chain has a commercial incentive to build it.




This argument applies primarily to the private passenger vehicle market. Two exceptions should be noted:

- **Insurance telematics (black box) programmes:** drivers voluntarily consent to persistent data collection in exchange for usage-based premiums. These programmes require data to survive across sessions to calculate risk scores. Chambers accommodates this through the preservation manifest — the insurer's declaration would specify multi-session retention for specific data categories, with the driver's explicit consent recorded in the manifest. The key difference is that retention becomes declared and bounded rather than silent and indefinite.
- **Fleet and commercial vehicles:** the data subject may be the employer rather than the driver, the legal basis is typically contractual necessity or legitimate interest, and regulatory telematics (e.g., tachographs under Regulation (EU) No 165/2014) mandate specific retention periods. A full treatment of fleet use cases is outside the scope of this paper.

# 5. The Legal Framework

Six EU regulatory instruments apply directly to connected vehicle data processing. This section maps each relevant provision to the specific vehicle data problem it addresses and identifies how Chambers provides architectural evidence supporting compliance.

> *Throughout this section, "supports compliance with" means the architecture provides technical mechanisms and auditable evidence that facilitate meeting the legal obligation. It does not mean the architecture alone is sufficient for legal compliance, which requires additional organisational, procedural, and contractual measures.*

## 5.1 GDPR (Regulation (EU) 2016/679)

The GDPR applies to all processing of personal data by connected vehicles. The EDPB confirmed this scope in Guidelines 01/2020 on processing personal data in the context of connected vehicles.

### Article 5 — Principles relating to processing

Article 5(1)(a) requires transparency. Current vehicle telemetry pipelines fail the transparency requirement because the driver cannot inspect what data is being collected or transmitted. The preservation manifest provides per-session visibility into data flows, supporting this principle.

Article 5(1)(b) requires purpose limitation. The GM/LexisNexis case demonstrated that vehicle data collected for diagnostics was sold to insurance data brokers — a purpose incompatible with the original collection. The manifest binds each data category to a stated purpose per stakeholder.

Article 5(1)(c) requires data minimisation. The preservation manifest declares exactly what persists, providing architectural evidence of minimisation. However, minimisation is ultimately a legal determination, not a technical one — the manifest provides the mechanism, but the controller must still justify that declared categories are adequate, relevant, and limited to what is necessary.

Article 5(1)(e) requires storage limitation. The burn engine enforces automatic session expiry. Retention periods are declared per stakeholder in the manifest.

Article 5(2) requires accountability. The audit log, produced automatically per session, provides the accountability artefact.

### Article 6 — Lawfulness of processing

The EDPB Guidelines 01/2020 state that consent for connected vehicle data processing must be provided separately from the vehicle purchase contract, for specific purposes, and may not be bundled. The manifest supports granular, per-stakeholder, per-category consent recording.

For processing under legitimate interest (Article 6(1)(f)), the manifest makes the balancing test auditable by declaring exactly what is retained and providing the driver with visibility. The EDPB has indicated that processing of location data through connected vehicles is likely to require careful justification under the balancing test.

### Article 17 — Right to erasure

The burn engine provides cryptographic erasure under current best practices: the session key is destroyed via the HSM's secure key deletion function, rendering encrypted session data unrecoverable under currently known cryptographic attacks.

> *Cryptographic erasure is not absolute erasure. If the encryption algorithm is broken in the future (including by quantum computing advances), or if the key was generated with insufficient entropy, residual risk exists. The paper characterises this as cryptographic erasure under current best practices, not provable mathematical erasure.*

Critically, cryptographic erasure applies only to data within the Chambers boundary. Once data has been transmitted to a third party under a manifest declaration (e.g., to an insurer's backend), erasure of that copy is the recipient's obligation under their own GDPR compliance. The Chambers architecture controls what leaves the vehicle and provides evidence of what was transmitted, but cannot enforce erasure at third-party systems.

### Article 25 — Data protection by design and by default

Article 25(1) requires the controller to implement appropriate technical measures designed to implement data-protection principles effectively. Article 25(2) requires that, by default, only necessary personal data are processed.

Chambers directly supports both obligations. The sealed session layer is the technical measure integrated into the processing architecture (by design). The default state is ephemeral — all data is encrypted under a session key that will be destroyed unless a declaration explicitly preserves specific categories (by default).

The CNIL's Connected Vehicles Compliance Package (2017) specifically recommends that data processing take place within the vehicle wherever possible and that connectivity features be deactivated by default. Chambers implements both recommendations architecturally.

### Article 30 — Records of processing activities

The preservation manifest describes intended processing categories per stakeholder. The audit log records actual processing — what data was generated, what was declared, what was transmitted, and what was burned. Together, the manifest and audit log provide the Article 30 record. The manifest alone is not sufficient, as it describes intended rather than actual processing.

### Article 35 — DPIA

The EDPB has confirmed that connected vehicle data processing likely requires a DPIA. The audit log, aggregated across sessions, provides the bounded data inventory needed for the DPIA's risk assessment.

### Articles 44–49 — International transfers

The manifest can include jurisdiction constraints that block transmission to non-EU endpoints, supporting Chapter V compliance at the network layer. However, this is a technical control, not a complete transfer mechanism — OEMs would still require appropriate safeguards (SCCs, adequacy decisions, or derogations) for any declared cross-border transfer.

## 5.2 ePrivacy Directive (2002/58/EC)

Article 5(3) applies to any entity that stores information on or gains access to information stored in terminal equipment. The EDPB has confirmed that a connected vehicle constitutes terminal equipment.

Chambers supports ePrivacy compliance by ensuring that no data is accessed or transmitted without a corresponding declaration in the manifest. The manifest provides the technical implementation mechanism for consent management, but does not substitute for the legal requirement of specific, informed, freely given consent. Consent must still be obtained through an appropriate user interface and recorded in compliance with applicable guidance.

## 5.3 UNECE R155 — Cybersecurity

R155 has been mandatory for all new vehicles since July 2024. Annex 5 lists 69 attack vectors. Several are directly relevant to data exfiltration:

| Annex 5 Ref | Threat | Chambers Mitigation |
|---|---|---|
| 4.3.1 | Abuse of privileges by staff | No raw data reaches backend; manifest limits categories |
| 4.3.3 | Unauthorised internet access to servers | Breach yields only current session's encrypted data |
| 4.3.6 | Data breach by third party | Per-stakeholder boundaries; each supplier sees only declared categories |
| 5.4.1 | Extraction from vehicle systems | Data encrypted at rest; key destroyed on session end |

## 5.4 EU Cyber Resilience Act (Regulation (EU) 2024/2847)

> *The CRA's Article 1(3) excludes products for which safety requirements are laid down in sectoral Union legislation, including type-approval regulations. Connected vehicles have type approval under Regulation (EU) 2018/858. Many legal commentators believe the entire vehicle, including embedded telematics, is excluded from CRA scope. The following analysis assumes a broad interpretation under which the OEM's cloud backend, mobile applications, and OTA infrastructure are in scope. This interpretation may not survive regulatory guidance or judicial review.*

The CRA entered into force on 10 December 2024. Reporting obligations apply from 11 September 2026. Full enforcement begins 11 December 2027.

Annex I requires products to be secure by default (no known exploitable vulnerabilities), to ensure confidentiality of data at rest and in transit, and to

minimise data processing. Chambers supports these requirements through ephemeral-by-default architecture and session-level encryption.

Article 14 requires 24-hour vulnerability reporting to ENISA. The Chambers architecture reduces the blast radius of any reported vulnerability: if a vulnerability is exploited in a vehicle with sealed session semantics, the incident report can state with architectural evidence what data was at risk and confirm that no historical session data was compromised.

## 5.5 EU AI Act (Regulation (EU) 2024/1689)

The AI Act classifies AI in autonomous vehicles as high-risk under Annex I. The compliance deadline for Annex I products is August 2027.

Article 10 requires that training data sets be subject to appropriate data governance. The Chambers sealed event mechanism captures bounded temporal windows around safety-critical events for model retraining, with declared purpose and retention periods. However, sealed events represent a biased sample (safety-critical events only). Normal driving data is also needed for representative training sets under Article 10(4). Sealed events are therefore a component of training data governance, not a complete solution. OEMs would still need to justify their overall sampling methodology.

Article 12 requires logging capabilities. The audit log provides a per-session record of all data flow decisions. Article 13 requires transparency to deployers. The driver-readable manifest supports this obligation. Article 14 requires human oversight, supported by driver and regulator visibility into data retention.

## 5.6 EU Data Act (Regulation (EU) 2023/2854)

The Data Act, applicable from September 2025, requires that connected products be designed to make data accessible to the user (Article 3) and that users can share data with third parties (Article 4). The manifest provides the data inventory and access control mechanism supporting these requirements.

## 5.7 Enforcement Precedents

### GM/LexisNexis (2024)

General Motors shared detailed driving behaviour data with insurance data brokers LexisNexis and Verisk without meaningful driver consent. Under a Chambers architecture, this data flow would have been blocked at the gateway unless the driver had explicitly approved an insurer declaration in the manifest.

### EDPB Guidelines 01/2020

The EDPB established that consent for vehicle data processing must not be bundled with the vehicle purchase contract; that Article 25 data protection by design applies to vehicle design; and that local processing within the vehicle

should be preferred. Chambers implements these recommendations architecturally.

### Volkswagen/Cariad Data Exposure (2024)

Volkswagen's software subsidiary left location data for approximately 800,000 electric vehicles accessible in an unsecured cloud system. Under Chambers, this data would not have existed in the cloud in raw form — only anonymised outputs declared in the manifest would have been transmitted.

# 6. Safety-Critical Exceptions

Several regulatory mandates require data retention that cannot be subject to driver consent or ephemeral session boundaries. The Chambers architecture must accommodate these without compromising its core model.

| Mandate | Data Required | Retention | Chambers Treatment |
|---|---|---|---|
| eCall (Reg. (EU) 2015/758) | Minimum data set: location, timestamp, VIN, direction | Transmitted on crash detection | Exempt: outside Chambers boundary, hardware-triggered |
| Event Data Recorder (EU Vehicle General Safety Reg.) | Pre-crash speed, braking, steering, seatbelt status | Write-once, survives power loss | Exempt: write-once partition outside session boundary |
| R155 Security Event Logging | Cybersecurity incidents and anomalies | Must survive session for forensic analysis | Exempt: declared as mandatory retention in manifest |
| Tachograph (Reg. (EU) 165/2014) | Driving time, rest periods, speed (commercial vehicles) | 28 days on vehicle, 365 days on driver card | Out of scope (commercial vehicles; noted for completeness) |

## 6.1 Architectural Treatment

Safety-critical data is handled through a hardware-protected, write-once partition that sits outside the Chambers sealed session boundary. This partition is:

- Physically separate from the session-encrypted data store.
- Write-once: data can be appended but not modified or deleted by software.
- Not subject to the burn engine: the session key destruction does not affect this partition.
- Declared in the manifest: the existence and categories of mandatory retention are visible to the driver, even though consent is not required.

This design preserves Chambers' core model (ephemeral by default) while accommodating regulatory exceptions (mandatory retention for safety). The key architectural principle is that even mandatory retention is declared and bounded — the driver can see what is retained and why, even if they cannot opt out.

## 6.2 HSM Failure and Fallback

If the HSM fails or is unavailable (hardware malfunction, supply chain constraint in lower-cost vehicles), the system must not render the vehicle inoperable. The fallback mode operates as follows:

- The vehicle remains drivable. Safety-critical functions are independent of the telematics gateway and Chambers layer.
- In fallback mode, the gateway applies a conservative default: no telemetry is transmitted until the HSM is restored. This is the most privacy-protective default.
- The audit log records the fallback event, including duration and the reason for HSM unavailability.
- Compliance claims for sessions during fallback are reduced — the OEM cannot claim cryptographic erasure for sessions where the HSM was unavailable.

## 6.3 Consent Revocation Mid-Session

If a driver revokes consent for a specific stakeholder during an active session, the manifest is updated immediately. Data already transmitted to that stakeholder during the current session cannot be recalled — recall is the recipient's obligation. However, from the point of revocation onwards, no further data in the declared category passes through the gateway for that stakeholder. The audit log records the revocation timestamp and the affected categories.

## 6.4 Law Enforcement Data Requests

If a session key has been destroyed, compliance with a law enforcement request for historical session data is architecturally impossible. This is by design, not by defect. The system cannot produce data that no longer exists in decryptable form.

For prospective requests (e.g., a warrant for future data collection), the manifest can be updated to add a law enforcement declaration with appropriate legal basis, enabling data capture in subsequent sessions. For concurrent requests during an active session, the current session's data remains available until the session ends.

This approach is analogous to encrypted communications: a lawful intercept order requires prospective collection, not retrospective decryption of destroyed keys. The same principle applies here.

# 7. Architected Regulatory Compliance Framework

This section consolidates the legal mappings from Section 5 into a structured framework tracing each Chambers component to the specific regulatory obligation it supports, the evidence it produces, and the verification method.

**Architected regulatory compliance framework**

*Each component mapped to obligation, regulation, evidence, and verification.*

| COMPONENT | OBLIGATION | REGULATION | EVIDENCE | VERIFICATION |
|---|---|---|---|---|
| SESSION SEAL | Data minimisation | GDPR 5(1)(c) | Session-scoped lifecycle | Manifest audit |
| | Secure by default | CRA Annex I(1) | No persistent store | Arch. review |
| | Terminal equip. | ePrivacy 5(3) | No undeclared access | Gateway logs |
| | Confidentiality | CRA Annex I(2) | Encrypted session data | HSM attestation |
| | Attack surface | R155 Annex 5 | Ephemeral = nothing to steal | Pen test |
| MANIFEST | Purpose limitation | GDPR 5(1)(b) | Per-stakeholder purpose | Schema audit |
| | Processing records | GDPR Art. 30 | Machine-readable log | Auto export |
| | Transparency | GDPR Art. 13 | Session summary to driver | HMI inspect |
| | Data governance | AI Act Art. 10 | Training data provenance | Conformity |
| | Human oversight | AI Act Art. 14 | Driver visibility into AI | User testing |
| | User data access | Data Act Art. 3 | Data inventory | API verify |
| | Supply chain risk | R155 7.2.2.2 | Per-supplier boundaries | Supplier audit |
| | Lifecycle docs | CRA Art. 13 | Living documentation | Version ctrl |
| BURN ENGINE | Right to erasure | GDPR Art. 17 | Key destruction log | HSM audit |
| | Storage limitation | GDPR 5(1)(e) | Auto session expiry | Retention check |
| | Data minimisation | CRA I(3a) | Undeclared irrecoverable | Forensic verify |
| | Blast radius | CRA Art. 14 | Breach = burned data | Incident sim |
| | Extraction prevent | R155 5.4.1 | Encrypted, no key | Red team |
| AUDIT LOG | Accountability | GDPR 5(2) | Per-session record | Regulator review |
| | Record-keeping | AI Act Art. 12 | Immutable event log | Integrity check |
| | Vuln reporting | CRA Art. 14 | Incident scope evidence | ENISA submit |
| | DPIA support | GDPR Art. 35 | Bounded data inventory | DPA review |
| | Gatekeeper block | Data Act 4(4) | Blocked tx log | Gateway audit |
| GATEWAY | By design | GDPR 25(1) | Architectural enforcer | Arch. review |
| | By default | GDPR 25(2) | Default = no egress | Config audit |
| | Transfer restrict | GDPR 44-49 | Jurisdiction constraints | Net monitor |
| | Frozen config | R155 L1 | Whitelisted destinations | Rule audit |
| | Sharing control | Data Act Art. 4 | Consent-gated sharing | Cross-check |

**28 obligations. 5 components. One compliance artefact.**

*Each row is a legal obligation satisfied architecturally, not through documentation.*

The framework maps 28 specific regulatory obligations across six EU legal instruments to five Chambers architectural components. Each obligation is supported by a structural property of the system rather than a policy document.

Each produces a specific compliance artefact. Each is verifiable through a defined method.

The practical significance is that an OEM integrating the Chambers gateway module does not need to engage six separate compliance workstreams. The five components, operating together on the telematics gateway, produce the compliance evidence for all 28 obligations as a by-product of normal operation.

# 8. The Regulatory Convergence Timeline

**Regulatory convergence timeline**

**April 2026 — today**

ALREADY LIVE
R155 / R156 — all new vehicles since July 2024

5 MONTHS
**Sept 2026 — CRA vulnerability reporting**
24-hour mandatory reporting to ENISA

4 MONTHS
**Aug 2026 — AI Act high-risk (Annex III)**
Autonomous driving classified high-risk

16 MONTHS
Aug 2027 — AI Act, Annex I (vehicles)

20 MONTHS
**Dec 2027 — CRA full enforcement**
Non-compliant products banned. €15M or 2.5%.

21 MONTHS
Jan 2028 — China GB 44495 (all vehicles)

**Cumulative penalty exposure**

CRA: €15M / 2.5% · AI Act: €35M / 7% · GDPR: €20M / 4%
R155: type approval refused · Data Act: €20M / 4%

# 9. The Chambers Architecture for Vehicles

## 9.1 Core Concepts

**Sealed drive sessions.** When the vehicle starts, the telematics gateway creates a session encrypted under an ephemeral key stored in the HSM. All data

flowing through the gateway is bound to that key. When the vehicle parks, the key is destroyed. Undeclared data becomes cryptographically unrecoverable under current best practices.

**Typed preservation manifest.** A grammar-constrained declaration specifying, per stakeholder: data categories, granularity (raw/aggregated/anonymised), retention period, identity linkage, purpose, jurisdiction constraints, and legal basis. The manifest is signed and immutable within a session.

**Burn engine.** Cryptographic key destruction via the HSM. This is a system property that provides cryptographic erasure under current best practices. It does not constitute mathematical proof of absolute erasure (see Section 6 caveat on residual risk).

## 9.2 Insertion Point: The Telematics Gateway

The telematics gateway is the primary chokepoint through which the majority of vehicle telemetry passes over cellular. It is viable because it is not safety-rated (no ASIL certification required), does not affect type approval, and handles the highest-volume data egress path.

> *The telematics gateway is not the only data egress point. Bluetooth tethering, direct third-party modem access (Android Auto, CarPlay), OBD-II physical extraction, and V2X short-range communications are additional channels not controlled by the gateway. Chambers provides protection for the cellular telemetry path, which carries the vast majority of data volume, but is not a complete solution for all egress channels. A comprehensive architecture would need to extend the sealed session boundary to these additional interfaces.*

## 9.3 Concept Mapping

**Concept mapping**

| CHAMBERS | VEHICLE | REGULATION |
|---|---|---|
| **World** | Drive session | GDPR processing scope |
| **Grammar** | Preservation manifest | Art. 30 processing record |
| **Allowed ops** | Declared data / stakeholder | Art. 5(1)(c) minimisation |
| **Burn engine** | Session key destruction | Art. 17 erasure proof |
| **Preservation law** | What survives, for whom | CRA lifecycle docs |
| **Sealed event** | ADAS incident recording | AI Act Art. 10 |

## 9.4 Regulatory Compliance Mapping

**How Chambers satisfies each regulation**

**GDPR — in force · €20M or 4%**

| | |
|---|---|
| Art. 5(1)(c) — Data minimisation | Preservation manifest |
| Art. 17 — Right to erasure | Burn engine |
| Art. 25 — By design / default | Ephemeral default state |
| Art. 30 — Processing records | Automatic audit log |

**R155 — July 2024 · No approval = no sale**

| | |
|---|---|
| CSMS — manage cyber risk | Sealed sessions |
| Annex 5 — attack vectors | Gateway enforcement |
| Supplier risk management | Per-stakeholder manifest |

**CRA — Sept 2026 / Dec 2027 · €15M**

| | |
|---|---|
| Secure by design | Ephemeral by default |
| 24h vuln reporting | Reduced blast radius |
| Lifecycle documentation | Manifest = documentation |

**AI Act — Aug 2026 / Aug 2027 · €35M**

| | |
|---|---|
| Art. 10 — Data governance | Sealed ADAS events |
| Art. 13 — Transparency | Driver-readable manifest |
| Art. 12 — Record-keeping | Immutable audit trail |

**Sovereignty — geopolitical imperative**

| | |
|---|---|
| Foreign exfiltration risk | Data never leaves unburned |
| No verification today | Machine-verifiable proof |

## 9.5 Stakeholder Data Flows Under Chambers

The preservation manifest does not eliminate data sharing. It makes data sharing explicit, auditable, and consent-gated:

**OEM:** Anonymised sensor health metrics, aggregated per drive cycle, stripped of location and identity. Retention: 90 days (example; actual periods would be determined by the OEM's DPIA). Legal basis: legitimate interest. Purpose: predictive maintenance.

**Insurer:** Acceleration, braking, and cornering severity scores per trip. No GPS, no timestamps beyond date. Retention: policy term. Legal basis: explicit consent, obtained separately. Purpose: risk model inputs.

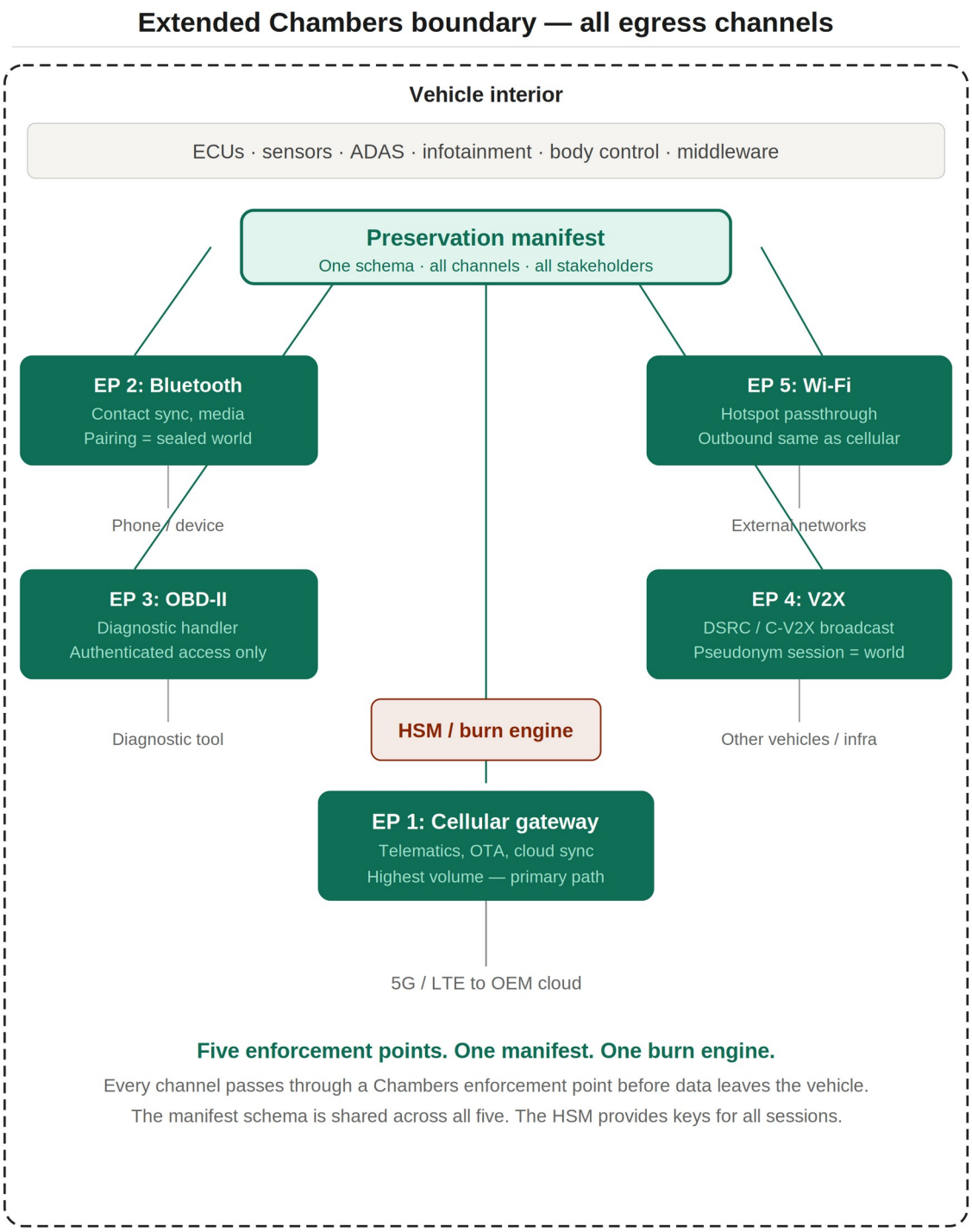
**ADAS supplier:** Sealed safety events only — bounded temporal windows around safety-critical triggers. Anonymised. Retention: 12 months. Legal basis: legitimate interest. Purpose: model retraining (component of training data governance under AI Act Art. 10).

**Tier-1 supplier:** Component-specific telemetry from their subsystem only. No driver identity. Retention: warranty period. Legal basis: contractual necessity.

Once data has been transmitted to a stakeholder under a manifest declaration, the recipient is responsible for their own GDPR compliance, including responding to erasure requests. Chambers controls what leaves the vehicle and provides evidence of what was transmitted, but cannot enforce erasure at third-party systems.

# 10. Extended Chambers Boundary: Beyond the Telematics Gateway

The original Chambers proposal targets the telematics gateway — the highest-volume data egress path. However, four additional channels carry data out of the vehicle, each with its own threat model and architectural constraints. A comprehensive architecture requires enforcement points at each channel.




## 10.1 Channel Analysis

The following matrix maps 16 specific threats across all five channels to the Chambers world type and enforcement point that addresses each:

**Per-channel threats and Chambers mitigations**

| CHANNEL | THREAT | CHAMBERS WORLD | ENFORCER |
|---|---|---|---|
| Cellular | Bulk telemetry exfiltration | Drive session | Gateway |
| | OEM cloud data hoarding | Drive session | Gateway |
| | Third-party data selling | Drive session | Gateway |
| | Foreign state backend access | Drive session | Gateway |
| Bluetooth | Contact/SMS sync persists | Pairing session | IVI VM |
| | Call history retained on resale | Pairing session | IVI VM |
| | Media metadata leakage | Pairing session | IVI VM |
| Wi-Fi | Passenger traffic inspection | Hotspot session | Gateway |
| | Outbound data over Wi-Fi | Drive session | Gateway |
| | Rogue AP data injection | Connection session | Gateway |
| OBD-II | Casual diagnostic extraction | Diagnostic session | Diag handler |
| | Insurance dongle bypass | Diagnostic session | Diag handler |
| | Stolen vehicle data dump | N/A (at rest) | HSM encrypt |
| V2X | Position tracking via CAMs | Pseudonym session | V2X stack |
| | Trajectory re-identification | Pseudonym session | V2X stack |
| | Inbound V2X data hoarding | Drive session | V2X stack |

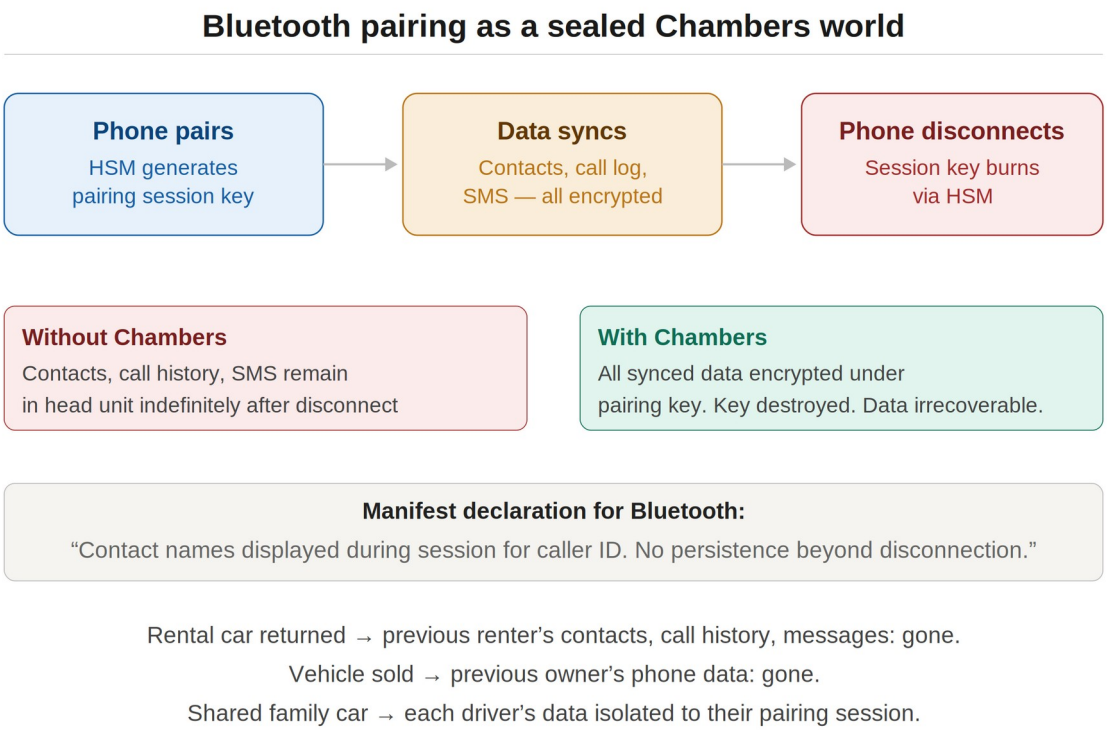
**16 threats. 5 channels. Each mapped to a Chambers world and enforcement point.**

*The cellular gateway covers 4 threats (highest volume). The remaining 12 require enforcement points at the infotainment VM, diagnostic handler, and V2X stack.*

## 10.2 Bluetooth

When a phone pairs with the vehicle, the infotainment system pulls contacts, call history, SMS messages, and media metadata via Bluetooth profiles (PBAP for contacts, MAP for messages, A2DP for media metadata). When the phone disconnects, this data typically remains in the head unit indefinitely. A rental car returned, a vehicle sold, a shared family car — previous users' personal data persists.

Bluetooth pairing maps naturally to a Chambers sealed world:




The enforcement point sits inside the infotainment VM (Android Automotive or Linux), intercepting Bluetooth profile data and encrypting it under a pairing-session key stored in the HSM. On disconnect, the key burns. All synced contacts, call logs, and media metadata become irrecoverable.

The manifest declaration for Bluetooth would specify: contact names displayed during session for caller ID, no persistence beyond disconnection. This is one of the cleanest applications of the model — the data lifecycle maps perfectly to the pairing session.

## 10.3 Wi-Fi

Two attack surfaces exist. First, the vehicle as a Wi-Fi hotspot: passenger devices connect through the vehicle's cellular modem. The vehicle can technically inspect this traffic. The Chambers manifest declares: "Wi-Fi hotspot: passthrough only, no inspection, no logging of passenger traffic." The gateway enforcement layer blocks any attempt to capture or store passenger data.

Second, vehicle outbound data over Wi-Fi (e.g., software updates downloaded at home). The same sealed session semantics apply as for cellular — the gateway enforcement point sits upstream of both the cellular modem and the Wi-Fi interface. Data leaving over Wi-Fi passes through the same manifest check. The channel changes; the policy layer stays the same.

## 10.4 OBD-II

This is the hardest channel because it is a physical port. Anyone with physical access can plug in a reader and extract diagnostic data — DTCs, PIDs, freeze frame data, VIN, and on some vehicles, live sensor streams. Insurance black boxes plug into OBD-II and stream data over their own cellular connection, completely bypassing the vehicle's telematics gateway.

Chambers can help in two ways:

- **Encrypted diagnostic responses:** ECUs encrypt diagnostic data under a session key, so only an authenticated diagnostic tool with the current session's credentials can read responses. AUTOSAR already supports SecOC (Secure Onboard Communication) for authenticated CAN messages. Extending it to encrypt OBD-II responses would prevent casual extraction by unauthorised devices.
- **Manifest declaration for OBD-II:** "Authenticated access only, session-scoped diagnostic responses." An aftermarket dongle without authentication credentials receives encrypted data it cannot decrypt.

> *Right-to-repair constraint: the EU Type Approval Regulation (EU) 2018/858 requires manufacturers to provide access to repair and maintenance information. The manifest must accommodate authorised third-party access (independent mechanics, MOT testing) while blocking unauthorised data extraction. This requires an authentication framework for independent repairers, which is an active area of EU regulatory development.*

Honest limitation: a sufficiently determined attacker with physical access and time can bypass software-level protections on OBD-II. Hardware-level countermeasures (authenticated connectors, physical port access control) are outside the Chambers architectural scope.

## 10.5 V2X (Vehicle-to-Everything)

V2X uses DSRC (5.9 GHz) or C-V2X (cellular) to broadcast Cooperative Awareness Messages (CAMs) and Decentralised Environmental Notification Messages (DENMs). These messages contain the vehicle's position, speed, heading, and dimensions, broadcast multiple times per second. Anyone within radio range can receive them.

The EU's C-ITS framework addresses tracking through pseudonymous certificates — the vehicle changes its identifier periodically. However, research has shown that trajectory analysis can re-identify vehicles even with rotating pseudonyms.

Chambers strengthens V2X privacy in two ways:

- **Pseudonym rotation as session boundary:** each pseudonym period is treated as a Chambers world. When the pseudonym rotates, the previous pseudonym's linkage data burns. Cross-session trajectory reconstruction becomes cryptographically harder because the linkage between consecutive pseudonym sessions is destroyed.
- **Inbound V2X data as ephemeral:** messages received from other vehicles and infrastructure are used for real-time situational awareness

but not stored. If an OEM wants to collect V2X data for traffic analysis, it requires a manifest declaration subject to the same minimisation and purpose limitation rules as any other data category.

The enforcement point for V2X sits in the V2X communication stack, which typically runs in a dedicated ECU or as a function in the central compute platform.

## 10.6 Architectural Summary

The extended Chambers architecture requires five enforcement points:

- EP 1: Telematics gateway (cellular) — covers bulk telemetry, OTA, cloud sync. Highest volume. Original scope of this paper.
- EP 2: Infotainment VM (Bluetooth) — covers contact sync, call history, media metadata. Per-pairing session lifecycle.
- EP 3: Diagnostic handler (OBD-II) — covers diagnostic extraction. Authenticated access with encrypted responses.
- EP 4: V2X stack (DSRC / C-V2X) — covers broadcast tracking and inbound data hoarding. Per-pseudonym session lifecycle.
- EP 5: Network layer (Wi-Fi) — covers hotspot passthrough and outbound data. Shares gateway policy.

All five enforcement points share one preservation manifest schema, one HSM-backed burn engine, and one audit log. The manifest is the single source of truth for what data may persist across any channel. The burn engine provides cryptographic erasure at session end regardless of which channel generated the data.

EP 1 (cellular) is the minimum viable product. It covers the highest-volume, highest-risk channel and is deployable as a gateway firmware module without modifying the vehicle’s safety-critical software. EPs 2–5 require deeper integration with the infotainment VM, diagnostic handler, and V2X stack respectively, and represent a phased expansion of the Chambers boundary.

# 11. Why the Industry Should Not Resist This

**Regulatory inevitability.** The compliance trajectory is clear. The question is not whether OEMs will have to limit data retention, but whether they get ahead of enforcement with an architecture that provides compliance evidence, or get caught in an enforcement action.

**Legal fragility.** Consent bundled with vehicle purchase is not freely given under GDPR Article 7 (per several DPA positions). If that interpretation holds, the legal basis for vehicle data collection collapses. The manifest provides fallback legal bases for specifically declared categories.

**Competitive differentiation.** One OEM with architecturally demonstrable privacy creates market pressure on every competitor.

**Data Act readiness.** The Data Act requires user data access and portability. The manifest provides the data inventory and access control mechanism needed to comply.

# 12. Implementation Path

**Route 1: Tier-1 middleware product.** Gateway firmware module sold to OEMs and tier-1 suppliers for integration. Fastest path to production.

**Route 2: Open-source SDV contribution.** Sealed session layer contributed to Automotive Grade Linux or Android Automotive OS. Wider adoption surface, slower path.

**Route 3: Fleet operator mandate.** Fleet operators contractually require a preservation manifest in vehicle procurement specifications.

# 13. Limitations

- No production implementation exists. The concept mapping is architectural, not validated on production telematics hardware. A prototype on representative hardware (e.g., NXP S32G) is required.
- The telematics gateway is the primary but not only data egress point. Section 10 extends the Chambers boundary to Bluetooth, Wi-Fi, OBD-II, and V2X, but EP 1 (cellular) is the minimum viable product. EPs 2–5 require deeper integration and represent a phased roadmap.
- The preservation manifest requires OEM cooperation to define the data taxonomy for each vehicle platform.
- Cryptographic erasure is not absolute. It provides protection under current best practices but is subject to future cryptographic advances, including quantum computing. The system should use post-quantum cryptographic algorithms as they become standardised for automotive use.
- The CRA’s applicability to vehicle-embedded telematics is legally contested. The analysis assumes a broad interpretation.
- Safety-critical data flows (eCall, EDR, security event logs) require mandatory retention outside the Chambers boundary (see Section 6).
- Sealed ADAS events provide a biased training data sample. They are a component of AI Act data governance, not a complete solution.
- Once data is transmitted to a third party under a manifest declaration, erasure of that copy is the recipient’s obligation. Chambers cannot enforce erasure at third-party systems.
- HSM availability is not universal, particularly in lower-cost vehicle segments. Deployment feasibility depends on the specific vehicle platform’s hardware capabilities.
- The retention periods cited in stakeholder examples (90 days, 12 months, etc.) are illustrative. Actual periods would be determined by the OEM’s DPIA and regulatory requirements.
- The legal analysis does not constitute legal advice. Compliance determination requires case-by-case assessment by qualified counsel.

# 14. Conclusion

The connected vehicle industry faces a regulatory convergence across six EU frameworks that demands architectural answers to what have historically been policy questions. GDPR asks: can you demonstrate data minimisation? The CRA asks: is your product secure by design? The AI Act asks: where does your training data come from? R155 asks: have you mitigated the listed attack vectors? The Data Act asks: can the user access their data? The ePrivacy Directive asks: did you obtain consent before accessing terminal equipment?

Chambers provides architectural evidence supporting compliance across all six frameworks through one intervention at the telematics gateway. The preservation manifest — together with the audit log — provides the GDPR processing record, the R155 risk evidence, the CRA lifecycle documentation, and the AI Act data governance artefact.

The driver sees a manifest that says: this drive session produced three declared outputs — anonymised fault codes to the manufacturer, an acceleration score to the insurer, one sealed ADAS event to the perception supplier. Everything else was destroyed. That is the compliance evidence. That is the thing no car on the road can produce today.

The regulatory deadline is not theoretical. September 2026 is five months away. December 2027 is twenty months away. Vehicle development cycles are eighteen to thirty-six months. The window to build this is now.

---

*github.com/therealgulkorinaga/chamber*